Zusammenfassung (secure as possible):

Unser Web Security Projekt umfasst einen secure Web-Email Service. Benutzer können sich registrieren, einloggen, E-mails senden und empfangen, sowie Anhänge hinzufügen. Das Ziel ist es zu versuchen die Website zu hacken/manipulieren.

Projekt Features:

- User management: Registrieren, Login, Logout
- Authentifikation: password hashing, password verification und storage
- Sessions: server-side Sessions mit Cookies -> Benutzer werden nach 1 Stunde automatisch ausgeloggt
- Brute-force: nachdem 5 mal der falsche Benutzername oder Passwort eingegeben wurde, muss 2 Minuten lang gewartet werden um nochmals 5 Versuche zu bekommen
- Mailbox: senden/empfangen von emails (subject, body, sender, recipient, timestamps) (im Ordner Database liegt die Struktur der DB)
- Anhänge: 3 Files pro E-mails möglich, maximal 10 MB pro File, und nur bestimmte Datentypen erlaubt: PDF, PNG, JPEG, TXT
- Databse queries mit prepared statements um SQL injection zu verhindern
- Flash messages, htmlspecialchars()
- Projekt wird über Docker gestartet

Architektur:

- Web (PHP, Apache) – UI, session handling, auth, file handling
- Database (MariaDB/MySQL)- tables: user, emails, email_attachments
- Storage volume – filesystem Ordner für alle Dateien die hochgeladen werden

DB schema:

- User(user_id, username(unique), password_hash, email, created_at)
- Emails(emails_id, sender_id, reciepient_id, subject, body, sent_at, status)
- Email_attachments(attachment_id, email_id, owner_id, orig_name, stored_name, mime_type, size_bytes, sha256, uploaded_at)

Threat model

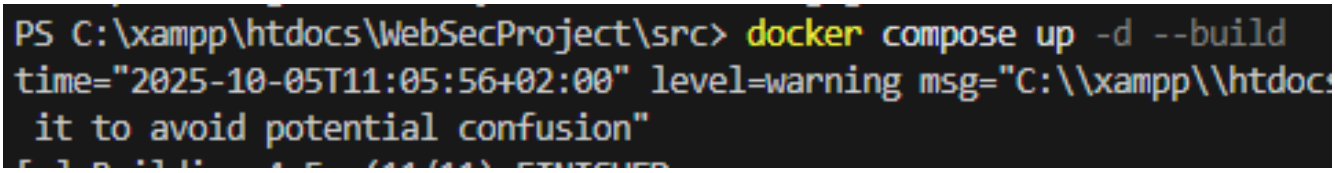
- User credentials (hashed)
- Stored messages and attachments
- Database contents

Implemented defense

- Cookies
- Password hash
- Session regeneration
- Alle SQL queries sind durch prepared statements vor SQL injection geschützt
- Htmlspecialchars
- Files werden auf erlaubten typen überprüft
- Files werden auf max MB überprüft
- DB credentails sind in .env File
- Projekt wird in Docker ausgeführt

Projekt ausführen (mit Docker)

- Docker Desktop starten
- im ordner WebSecProject/src -> terminal command: docker compose up -d –build

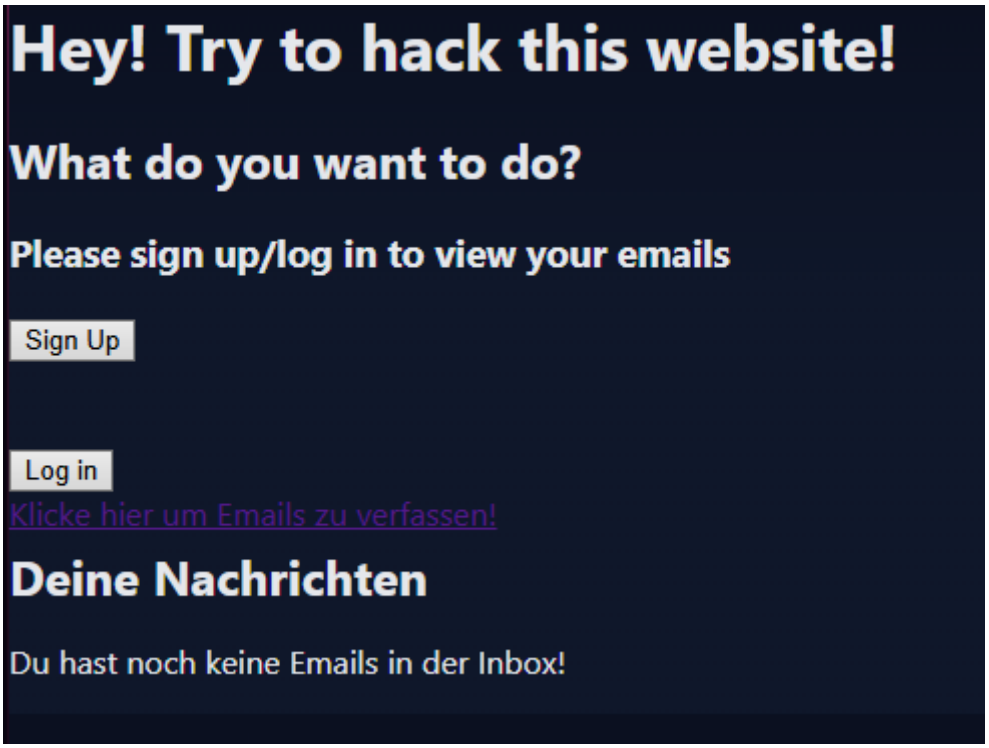


- im Browser http://localhost:8080 aufrufen
- fertig!

Es gibt 2 vorgegebene Benutzer, aber man kann auch einfach mehrere durchs registrieren erstellen.

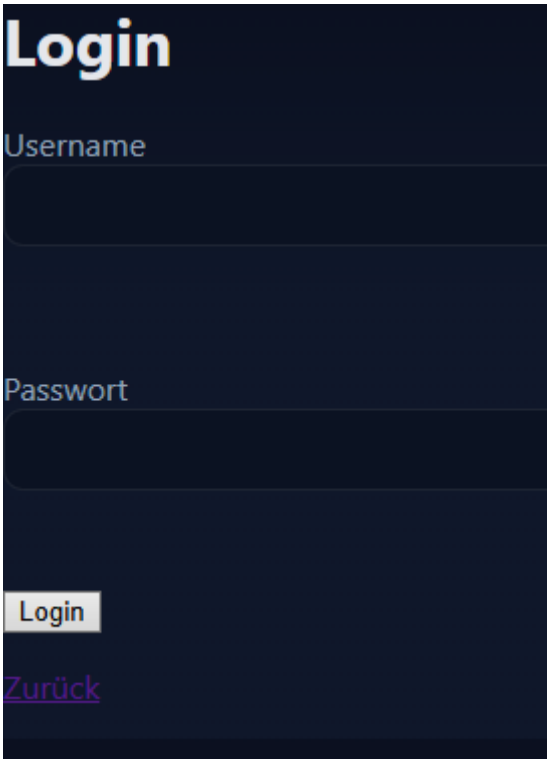
Website:

Index.php



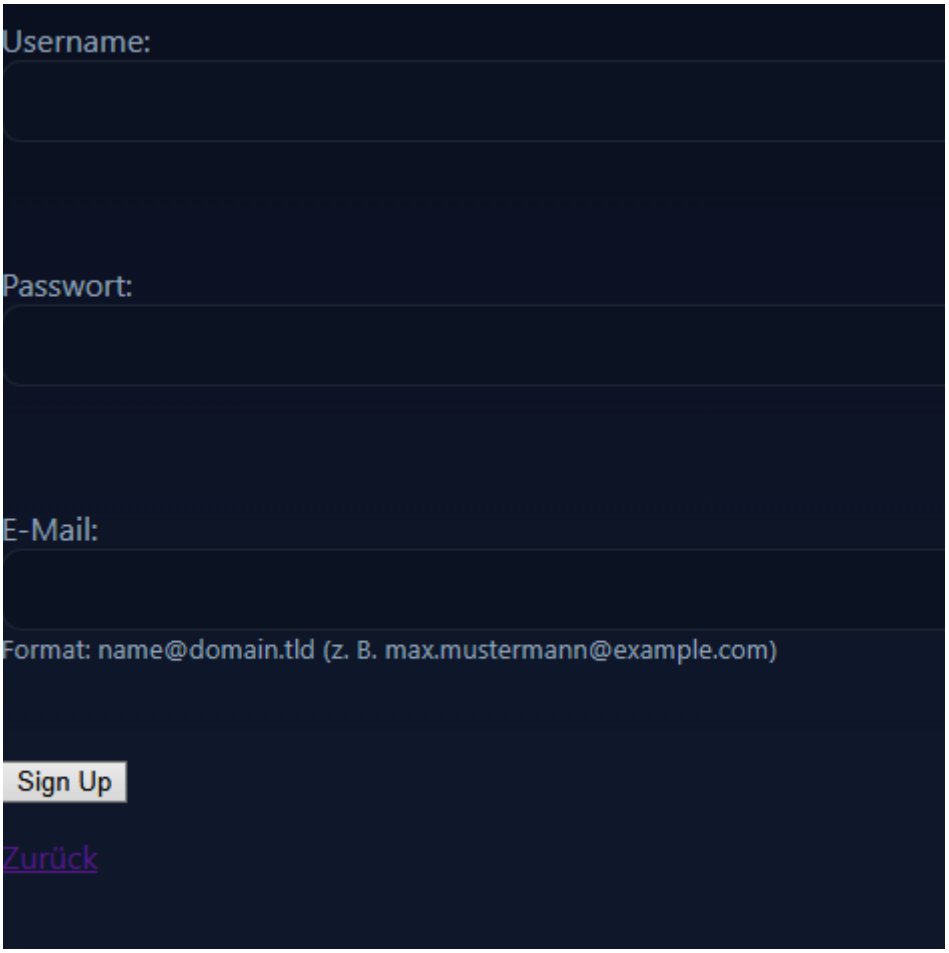
Auf dieser Seite kannst du alle deine Emails sehen, sowie registrieren und einloggen

Login.php



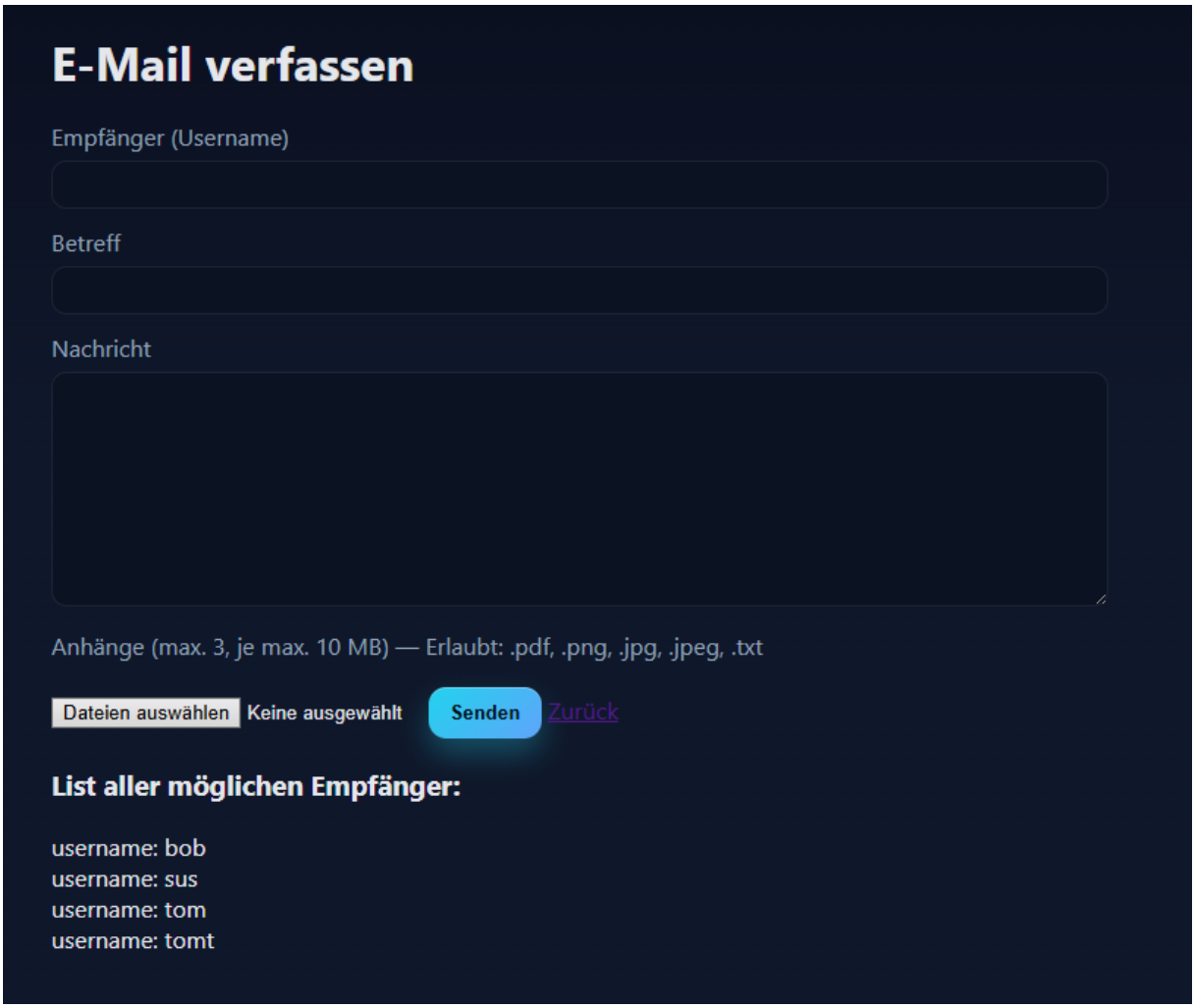
Hier ist ein einfaches login möglich

Signup.php



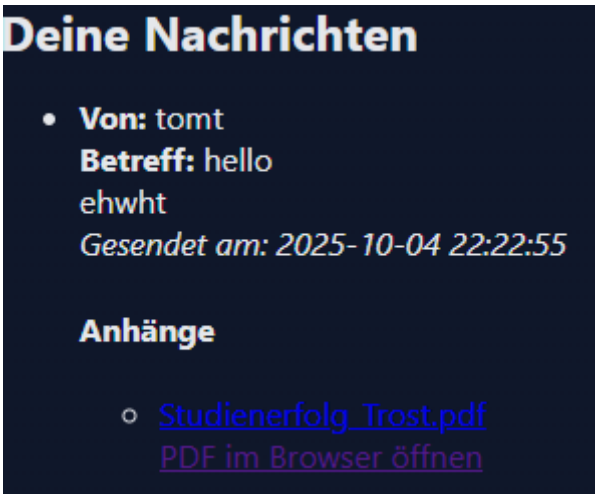
Registrierung einfach möglich (bei der Email muss das richtige format eingehalten werden wie im Beispiel gezeigt, da sonst die registrierung nicht klappt, weil es keine korrekte Email addresse ist.)

Compose.php



Hier können emails verfasst werden, um es einfacher zu gestalten haben wir unten eine liste aller möglichen user angegeben welcher als Empfänger eingetragen werden können. Es wird empfohlen selbst 2 user anzulegen um zum einen Nachrichten zu schreiben und mit dem anderen Benutzer die nachrichten dann angezeigt bekommen

Hier habe ich mich zum Beispiel zuerst mit tomt eingeloggt, eine Email verfasst, dannach mit dem user sus eingeloggt und die Email gelesen.



Anhänge können heruntergeladen werden

Bitte selbst accounts auf der Website anlegen, danke! 😊

Viel Spaß beim hacken!